

Manual 33 — SEC Cybersecurity Governance and Disclosure Controlled Implementation

****Language:**** English

****Regulatory baseline:**** SEC Release No. 33-11216, Cybersecurity Risk Management, Strategy, Governance, and Incident Disclosure, effective September 5, 2023, with current forms and official SEC guidance reverified on 2026-08-31.

****Controlled boundary:**** This manual is implementation guidance. It does not provide legal advice, determine issuer status or materiality, authorize delayed disclosure, make a filing, or certify compliance. Binding SEC rules/forms, Commission or staff guidance, proposals/non-effective material, enforcement facts, and issuer practices remain distinct.

Chapter 01 — Purpose, scope, and controlled-source hierarchy

Use current SEC rules and forms as the binding source layer. Treat Commission/staff guidance, compliance guides, speeches, FAQs, enforcement materials, petitions, and proposals according to their actual legal status and date; internal disclosure procedures must never be presented as SEC rules.

Chapter 02 — Issuer status and applicability analysis

Maintain a documented assessment of registrant type, Exchange Act reporting status, domestic versus foreign private issuer treatment, applicable forms, reporting calendar, and disclosure-control ownership. Escalate ambiguous issuer-status questions to qualified securities counsel.

Chapter 03 — Definitions and terminology governance

Maintain a controlled glossary for cybersecurity incident, cybersecurity threat, information systems, materiality, board oversight, management role, disclosure controls, Form 8-K, Form 6-K, Form 10-K, Form 20-F, Regulation S-K Item 106, and Inline XBRL. Preserve SEC meaning when internal terminology differs.

Chapter 04 — Cybersecurity governance and board oversight

Document how the board or responsible committee oversees material risks from cybersecurity threats, including information flows, cadence, escalation, significant incidents, risk trends, and management reporting. Governance records should support accurate annual disclosure without turning ordinary board materials into unsupported legal conclusions.

Chapter 05 — Management roles and accountability

Define accountable management roles for assessing and managing material cybersecurity risks, including CISO/security, legal, finance, disclosure committee, investor relations, risk, technology, and executive leadership. Record responsibilities, expertise, escalation paths, and evidence relevant to Item 106 disclosure.

Chapter 06 — Enterprise risk-management integration

Integrate cybersecurity risk identification and treatment into enterprise risk-management processes so material effects and reasonably likely material effects can be evaluated consistently with other business risks. Preserve links among cyber-risk records, business impact, strategy, financial reporting, and disclosure workpapers.

Chapter 07 — Cybersecurity risk identification and prioritization

Maintain a repeatable process for identifying, assessing, prioritizing, and managing cybersecurity threats and related business impacts. Include third-party dependencies, prior incidents, technology change, data exposure, operational disruption, legal/regulatory consequences, and reasonably likely material effects.

Chapter 08 — Materiality governance and decision records

Use a documented, issuer-specific materiality process grounded in federal securities-law standards and appropriate counsel involvement. Preserve facts, quantitative and qualitative considerations, uncertainty, decision authority, timing, dissent or unresolved questions, and the basis for the final determination.

Chapter 09 — Incident discovery and escalation

Establish cross-functional incident escalation that promptly connects security operations with legal, disclosure, finance, investor relations, privacy, business, and executive stakeholders when an incident could become material. Record discovery, investigation milestones, known impacts, evolving facts, and materiality-review triggers.

Chapter 10 — Form 8-K Item 1.05 decision process

For domestic registrants, maintain a controlled decision process for whether a cybersecurity incident has been determined material and therefore requires Item 1.05 disclosure. Do not use Item 1.05 merely because an incident is severe internally; the trigger is the issuer's materiality determination.

Chapter 11 — Four-business-day filing timing control

Once a domestic registrant determines a cybersecurity incident is material, track the general four-business-day Form 8-K deadline from the determination date. Maintain timestamped decision records, filing-calendar checks, review ownership, contingency coverage, and evidence of timely filing or a valid delayed-disclosure process.

Chapter 12 — Delayed-disclosure and Attorney General process boundary

Treat delayed disclosure for substantial national-security or public-safety risk as a specific rule-governed process, not an internal management choice. Preserve counsel analysis, government communications, written determinations or notifications, applicable extensions, timing, and confidentiality controls.

Chapter 13 — Incident disclosure content governance

Draft Item 1.05 disclosure around the material aspects required by the rule, using verified facts and avoiding unnecessary sensitive technical detail. Maintain source support, review comments, legal and executive approval, version history, consistency checks, and evidence that speculative or operationally sensitive statements were controlled.

Chapter 14 — Amendment and corrective-disclosure controls

Monitor facts after an initial filing and maintain a process for amendments or corrective disclosure when required by current rules or when prior disclosure becomes materially incomplete or inaccurate. Preserve the reason, new facts, legal analysis, approvals, filing version, and linkage to the original disclosure.

Chapter 15 — Regulation S-K Item 106 annual disclosure

Maintain annual disclosure workpapers supporting the required description of cybersecurity risk-management processes, material effects or reasonably likely material effects, board oversight, and management roles. Reconcile annual narrative to actual governance, risk, incident, and assurance evidence.

Chapter 16 — Risk-management process disclosure

Document how the issuer assesses, identifies, and manages material risks from cybersecurity threats, including integration into overall risk management, use of assessors or other third parties where material, and processes for overseeing risks associated with third-party service providers.

Chapter 17 — Board oversight disclosure

Support annual board-oversight disclosure with accurate governance records showing how the board or committee receives information and exercises oversight. Avoid boilerplate that cannot be supported by minutes, materials, reporting cadence, or actual oversight practice.

Chapter 18 — Management expertise and role disclosure

Maintain evidence supporting disclosure of management positions or committees responsible for assessing and managing material cyber risks, relevant expertise where disclosed, and the processes by which management is informed and reports to the board.

Chapter 19 — Foreign private issuer Form 6-K boundary

For foreign private issuers, maintain a separate analysis of Form 6-K cybersecurity incident obligations and the relationship to disclosure or publicity in a foreign jurisdiction, stock exchange, or to security holders. Do not apply domestic Form 8-K mechanics automatically.

Chapter 20 — Foreign private issuer Form 20-F boundary

Maintain annual Form 20-F workpapers for cybersecurity risk management, strategy, and governance disclosures applicable to foreign private issuers. Reconcile terminology and timing to the current form rather than copying domestic Form 10-K language without analysis.

Chapter 21 — Inline XBRL tagging controls

Apply current Inline XBRL tagging requirements to required cybersecurity disclosures. Maintain taxonomy/version control, tagging review, validation evidence, filing-preview checks, correction handling, and coordination between disclosure owners and filing vendors or systems.

Chapter 22 — Disclosure controls and procedures

Embed cybersecurity disclosure into the issuer's disclosure controls and procedures. Define information capture, escalation, materiality review, drafting, approval, filing, evidence retention, testing, deficiency management, and periodic control reassessment.

Chapter 23 — Legal, investor-relations, security, and executive coordination

Maintain a cross-functional disclosure protocol that preserves security facts, legal judgment, market communications, financial implications, executive accountability, and consistent messaging. Define decision rights and emergency availability before an incident occurs.

Chapter 24 — Evidence preservation and disclosure workpapers

Preserve incident facts, source records, materiality analyses, disclosure drafts, approvals, filing timestamps, board and management evidence, annual disclosure support, and control-testing records in a traceable workpaper structure with appropriate access restrictions and retention.

Chapter 25 — Third-party incident and dependency considerations

Include third-party systems, cloud providers, processors, vendors, and material dependencies in incident and risk analysis. Maintain facts about ownership, notification, business impact, data exposure, contractual rights, investigation limitations, and issuer-specific materiality without assuming a vendor's conclusion determines the issuer's disclosure duty.

Chapter 26 — Cyber insurance and risk-transfer disclosure considerations

Treat cyber insurance, indemnity, and other risk-transfer arrangements as contextual risk-management evidence rather than substitutes for incident response or disclosure obligations. Preserve coverage facts, limitations, material recoveries or exposures, and coordination with disclosure and financial-reporting teams where relevant.

Chapter 27 — Enforcement, litigation, and investigation interface

Track SEC enforcement developments, litigation, investigations, and interpretive developments as dated evidence that may inform governance and controls. Do not convert case-specific allegations, settlements, or judicial rulings into universal requirements without legal analysis.

Chapter 28 — Confidentiality, privilege, and need-to-know controls

Coordinate evidence preservation and disclosure work with counsel to manage privilege, work product, confidentiality, market-sensitive information, security-sensitive technical facts, and need-to-know access. Confidentiality controls must not be used to obstruct required disclosure or record retention.

Chapter 29 — Metrics, reporting, and continuous improvement

Define metrics for incident escalation timeliness, materiality-review cycle time, disclosure readiness, control testing, third-party information availability, annual-disclosure evidence quality, filing defects, and remediation. Use trends to improve governance rather than as standalone proof of compliance.

Chapter 30 — Independent review and disclosure assurance

Use independent legal, internal-audit, compliance, or control-assurance review as appropriate to test the design and operation of disclosure processes. Preserve scope, independence, evidence sampled, findings, limitations, remediation, and closure; do not describe internal review as an SEC approval or audit opinion.

Chapter 31 — Evidence architecture, traceability, and retention

Maintain traceability from SEC rule/form requirement to policy, procedure, owner, system, incident, materiality decision, disclosure workpaper, filing, control test, finding, remediation, and source version. Apply retention and access controls consistent with securities-law, litigation, investigation, and organization requirements.

Chapter 32 — Release-time source reverification and implementation roadmap

Before each controlled release, revalidate Release 33-11216, current Forms 8-K/6-K/10-K/20-F, Regulation S-K Item 106, Inline XBRL requirements, current SEC guidance, and any effective amendments. Record changes, impact decisions, updated controls, training, workpapers, and implementation actions through controlled change governance.

Minimum implementation evidence set

Maintain, as applicable: issuer/applicability assessment; controlled SEC source register; governance and management accountability evidence; cyber-risk register; materiality methodology and decision records; incident escalation records; Item 1.05 decision and timing evidence; delayed-disclosure records where applicable; disclosure drafts/approvals; annual Item 106 workpapers; FPI analysis; Inline XBRL validation; disclosure-control testing; legal/IR/security coordination records; third-party incident analysis; assurance findings; remediation evidence; and release-time source verification.